COMPSCI5079(M)
Cryptography & Secure Development

Dr. Nguyen Truong

Lecturer (Assistant Professor), SoCS, University of Glasgow

Email: Nguyen.Truong@Glasgow.ac.uk

Office: SAWB 221C, Sir Alwyn Williams Building, 18 Lilybank Gardens

Lecture 4:

Message Digests, Random Numbers and Secret Sharing

Lecture 3:

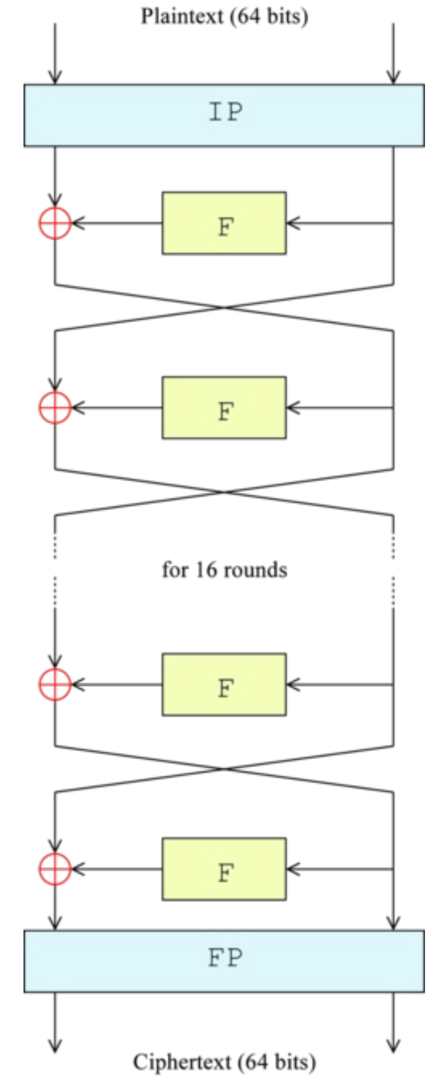
Review

Main points to take home

1) The Feistel family of algorithms were designed to be fast.
   - The block size was two computer words. All the calculations were done in a single computer word of 32 bits (half of the block).
   - There were several rounds with sub-keys generated from a master key.
   - In each round:
     - A substitution is performed on the left half L_i
     - A permutation is performed by swapping the two halves.
   - Decryption used the same algorithm but with the sub-keys in the reverse order.

Main points to take home

2. DES was an implementation of the Feistel scheme.
   - The chosen key length of 56 bits was too short.
   - It used fairly random lookup tables in each round.
   - All the operations were fast and required a small amount of computation.
   - The short key length led to it being broken about 20 years after adoption.
   - The triple-DES version is secure and still in use in major applications.



Main points to take home

- Simplified-DES
  - To understand how DES works, we study a toy system Simplified-DES (S-DES) developed by Edward Schaefer of the University of Santa Clara.
  - S-DES encrypts 8-bit blocks of data using a 10-bit key.
  - There are two substitution rounds, each with its own sub-key.
  - Left and right halves are swapped between them.

Main points to take home

3. AES was adopted after an open competition.
   - It uses many rounds, each with its own subkey.
   - All the operations are fast and don't require much silicon.
   - The basic transformations use mathematics so it can be proved to be secure from all known attacks.
   - Both the key and block size can be 128, 192 or 256 bits long.

AES Encryption Algorithm

```
AddRoundKey(S, K[0]);
for (int round = 1; round <= 10; round++){
      SubBytes(S);
      ShiftRows(S);
      if (round != 10)  //Not final round
            MixColumns(S);

      AddRoundKey(S,K[round]);
  }
```

Reading Session

- The following table lists the number of bits that have changed after each round of DES with
  - two very similar plaintext blocks (diffusion).
  - two very similar keys (confusion).
- Diffusion and confusion are quite effective.
- Permutations on their own do not affect confusion or diffusion.
  - 1-bit change in the origin only changes one bit in the destination.

Round	Confusion	Diffusion
1	6	2
2	21	14
3	35	28
4	39	32
...	...	...
10	44	38
11	32	31
12	30	33
13	30	28
14	29	34
15	29	34
16	34	35

Quizzes

1. What is Differential Cryptanalysis?

2. For DES, at round 4, the Confusion and Diffusion are quite effective enough. Why do we need to perform the algorithm until round 16?

Differential Cryptanalysis of DES-like Cryptosystems

(Extended Abstract)

Eli Biham *Adi Shamir*

The Weizmann Institute of Science
Department of Applied Mathematics

Abstract

The Data Encryption Standard (DES) is the best known and most widely used cryptosystem for civilian applications. It was developed at IBM and adopted by the National Buraeu of Standards in the mid 70's, and has successfully withstood all the attacks published so far in the open literature. In this paper we develop a new type of cryptanalytic attack which can break DES with up to eight rounds in a few minutes on a PC and can break DES with up to 15 rounds faster than an exhaustive search. The new attack can be applied to a variety of DES-like substitution/permutation cryptosystems, and demonstrates the crucial role of the (unpublished) design rules.

Lecture 4:

Message Digests, Random Numbers and Secret Sharing

Outline

1. Message Digest
   - Message Digest Concept
   - Design a Hash Function
2. Random Numbers
   - Real Random numbers
   - Pseudo-random numbers
   - Cryptographically Secure Pseudo-random numbers
3. Secret Sharing (Multiple key cryptography)
   - Secret Splitting
   - Secret Sharing

Message Digest Concept

- The message digest (MD) of a message is a smaller 'fingerprint' that can uniquely identify the message.
- A message digest can be signed with a secret key.
  - Message Authentication Code (MAC)
- It will be just as valid as a signed version of the original document.
  - Provided a different document with the same message digest cannot be created.

Requirements of Message Digest

1. Given the message, it is **easy** to compute the **message digest**.

2. Given the message digest, it is **hard** to compute the **message**.

3. Given a **message M**, it is **hard** to find another **message M'** with the same message digest.
   - This is also called a pre-image collision attack.

4. It should be **hard to find** two random messages **M** and **M'** with the **same message digest**.
   - This is also called a collision attack or a birthday attack.

Requirements of Message Digest

Easy to compute, hard to reverse:

- Requirement 1: easy to compute MD
- Requirement 2: implies that the hash function cannot be reversed, and the original message must be long enough.
  - If the message were only 64 bits long, for example, then a Brute Force attack could be used.
  - Try all possible 64-bit messages, seeing which produces the required digest.

Requirements of Message Digest

Effectively Unique:

- Requirement 3 is vital because:
  - It prevents one document whose MD has been signed from being replaced by another document with the same MD.
- Requirement 4 is more subtle and relies on the following statistical facts:
  - Birthday Attack

Birthday Attack

- How many people must be in a room before there is a greater than even probability (50% chance) that one of them shares a birthday with me?
  - **Answer 183.**

- How many people must be in a room before there is a greater than even probability that two of them share a birthday (***Birthday paradox***)?
  - **Answer 23.**

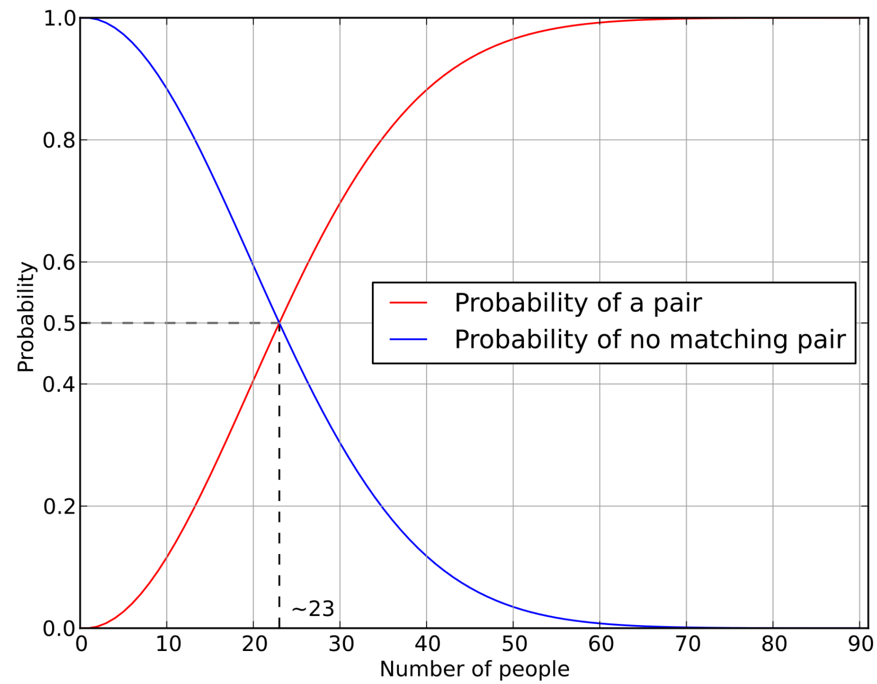
- It is much easier to find two random people with the same birthday than it is to find someone with the same birthday as a specified person.

Birthday Paradox

- How many people must be in a room to make sure that we can always find two people sharing the same birthday?
  - It's 366, obviously!

- How many people must be in a room to make sure that the probability of finding two people sharing the same birthday is greater than even probability (50%)?
  - It's 23? Why?

The birthday paradox refers to the counterintuitive fact that only 23 people are needed for that probability to exceed 50%.



https://en.wikipedia.org/wiki/Birthday_problem

Birthday Attack with Documents

- Again, it is much easier to find two random people with the same birthday than it is to find someone with the same birthday as a specified person.

- If we start with one document, we can create many different documents that look similar by:
  - Adding a space at the end of a line.
  - Adding a space/backspace combination.

- Let us assume that the message digest has m bits.
- Finding another document with the same message digest requires around 2^m attempts.
- Finding two random documents with the same message digest requires around $2^{m/2}$ attempts.
  - It will require building a table of previous attempts.

Birthday Attack Example

- Let us assume that `m = 8`, so there are 256 possible message digests.
- We have a document D with message digest MD.
- We want to create another random document with the same message digest MD.
- Each random document with have a 1/256 chance of doing this.
- We would need to try around 128 random documents (half of 256), on average, to find one.

Birthday Attack Example

- Now let us make 15 random changes to document D. We have a total of 16 target MD values.
  - We store them in a lookup table.
- Now make random changes to the second document.
- Each change will have a 1/16 chance of matching one of the 16 target MD values.
  - On average we need to create 8 documents.
- We need to create about 16+8 = 24 random documents to have a 50% probability of finding a match.
  - This is a lot easier.

Size of Message Digest

- If $m = 64$ then the first problem requires $2^{64} = 10^{19}$ attempts, while the second requires $2^{32} = 10^{10}$ attempts.
- 64 bits is too small to survive a birthday attack, and the message digest must be at least 128 bits long.
  - In practice, they are usually 256 bits long.

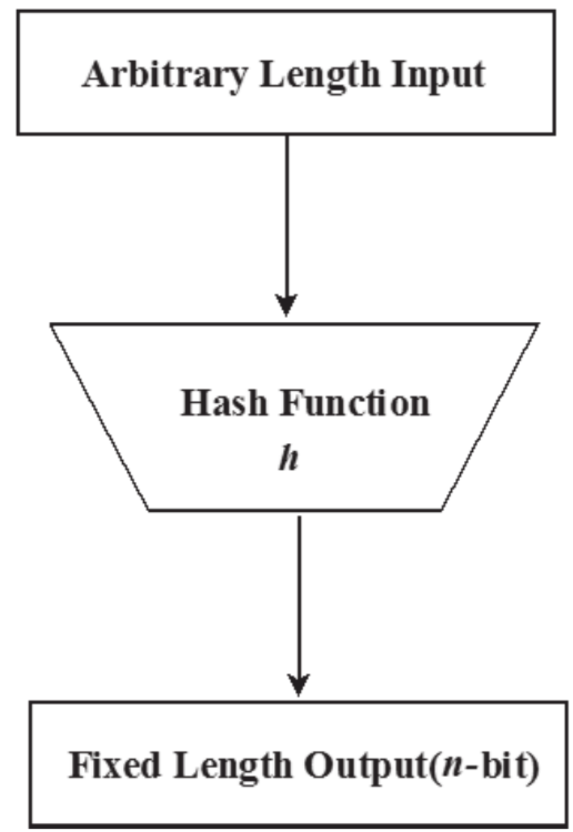
Designing a Hash Function

General Form of Hash Functions

- Hash functions take a document and produce a message digest.

- Hash functions have to reduce the size of a document, and normally work by first breaking the document into blocks, each the same length as the final hash value.

- A function is defined that takes two blocks as input and one as output.
- The function is then called iteratively:
- Its two inputs will be:
  - The previous output
  - The next message block.



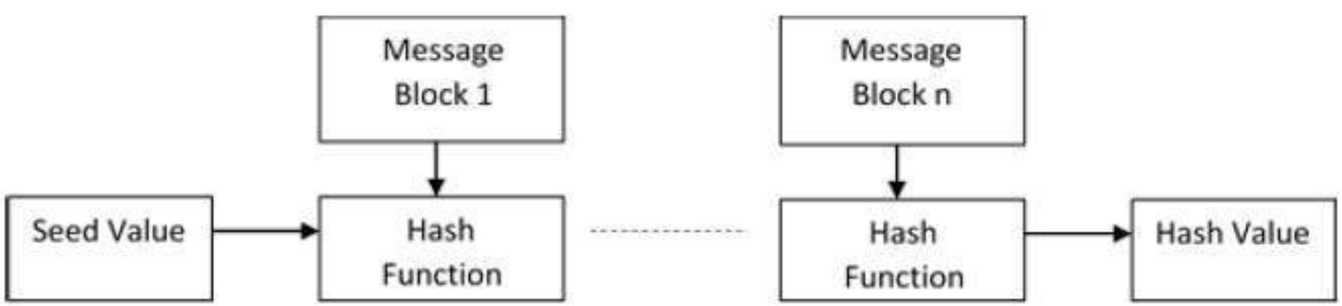
General Form of Hash Functions

- We have.

  $h_i = f(M_i,\ h_{i-1})$

- The function f is usually a combination of ⊕ and other simple operations.
- The result of the hash function will be the final value of h when the iteration has finished.
- Hash function algorithms are similar to single-key encryption algorithms.

- We will not go into details of these algorithms.



A Survey of Hash Functions

- MD5 was invented by Ron Rivest of RSA fame (see later)
  - 128 bits.
  - Found to be vulnerable to a birthday attack.
- SHA-1 was produced by NIST
  - Secure Hash Algorithm 1
  - 160 bits
  - Found to be vulnerable to a birthday attack.
- SHA-2 was also produced by NIST, with 4 versions
  - SHA-256 (or 224); SHA-512 (or 384) bits
  - Secure so far.
- SHA-3 public competition with adoption in 2012.

The SHA-3 Competition

- Following the success of the AES competition, NIST announced a competition for a message digest, to be called SHA-3, in November 2007.
- 64 entrants were submitted by October 2008
- 51 were accepted for the first round and public scrutiny began.
  - About 20 were broken.
- 14 made it into the second round.

The SHA-3 Competition

- 5 finalists were announced in December 2010.
  - BLAKE (Jean-Philippe Aumasson et. al.)
  - Grøstl (Knudsen et. al.) based on AES.
  - JH (Hongjun Wu)
  - Keccak (Daemen et. al.)
  - Skein (Schneier et. al.)
- All finalist's functions were tweaked in response to public analysis.
- The winner, announced in October 2012, was Keccak.
  - Their entry was significantly faster than the others.
- NIST wanted to change Keccak slightly to trade off security for speed but backed off because of the climate of mistrust.

Algorithmic Features

- NIST encouraged different styles of algorithms, which can be classified into 3 groups:
  1. Similar to existing algorithms
  2. Similar to AES
  3. Based on manipulating a small number of bits.

- Keccak is in the 3rd group and is a ‘sponge’ algorithm.

- The public scrutiny did not reveal any new classes of attack.

Last Block Padding

- SHA-256 padding
  - The message is processed as 512-bit blocks, and so must be padded out initially to a multiple of 512 bits.
  - Firstly, a 64-bit representation of the length of the document is prepared.
  - Then the document is padded out to 64 bits less than a multiple of 512 bits by adding a 1 bit, followed by as many 0's as necessary.
  - Finally, the 64-bit length is added at the end.

- Keccak padding
  - A 1-bit is added, followed by as many 0-bits as necessary and then a final 1-bit.

Summary

- Message Digests
  - Use a one-way hash function.
  - Four requirements for Message Digest
  - Resistant to a birthday attack (collision)

  - Some popular Hash functions have been proposed
  - Open competition for SHA-3

Quiz

1. Explain the term message digest. Explain why a 64-bit message digest is vulnerable to misuse.

2. `Fasthash` is a special-purpose chip that can calculate the message digest of a standard legal document in 10^{-6} seconds. The message digest produced is a convenient 32 bits and can be stored as an integer. Lawyer Bob has prepared 2 different documents entitled "Rip Off" and "Sweet Deal" respectively. He knows the message digest produced by the "Sweet Deal" document.
   - Describe how he might modify the "Rip Off" document so that it produces the same message digest as the "Sweet Deal" document.
   - Roughly how long will it take him to do so, assuming that document editing time is negligible? Describe in detail how he could achieve the same aim in less time.